

Information Security Policy Pack

Governance baseline for a mid-sized organization

Document Owner	Security Governance
Review Cycle	Annual
Version	1.0
Classification	Internal Use

Prepared by Gustavo do Carmo Lemes as a governance documentation exercise, reflecting the structure and rigor expected in a real information security policy set.

1. Information Security Policy

Purpose: Define the organization’s overall commitment to protecting information assets and maintaining security governance across people, process, and technology.

Scope: Applies to employees, contractors, third parties, information assets, and systems that store, process, or transmit organizational data.

Policy Statements

- Information assets shall be protected according to business criticality, sensitivity, and regulatory obligations.
- Security roles and responsibilities shall be assigned for all critical systems and business processes.
- Exceptions to security requirements must be documented, risk-assessed, approved, and reviewed periodically.
- Security incidents and policy violations shall be reported promptly through approved channels.

Roles and Responsibilities

Role	Responsibility
Executive Leadership	Provide strategic oversight and support for security governance
Security Team	Maintain standards, monitor compliance, and advise on risk treatment
System Owners	Ensure controls are implemented for assigned systems
All Personnel	Follow policy requirements and report incidents or suspicious activity

2. Access Control Policy

Purpose: Ensure that access to systems and data is granted, modified, reviewed, and revoked in a controlled manner consistent with least privilege and business need.

Requirements

- Every user account must be uniquely assigned to an identifiable individual or managed service account owner.
- Access requests must be approved by the relevant manager and system owner before provisioning.
- Privileged access must be tightly restricted, logged, and reviewed at least quarterly.
- Dormant accounts and terminated-user access must be removed promptly according to defined offboarding timelines.

3. Password and Authentication Standard

- Passwords must be at least 12 characters in length or use an approved passphrase model.
- Multi-factor authentication is required for administrator accounts, remote access, and systems handling confidential data.
- Default passwords must be changed before systems are placed into service.
- Shared accounts are prohibited unless formally approved, documented, and technically controlled.

4. Incident Response Policy

Purpose: Establish a consistent approach for identifying, escalating, containing, investigating, and recovering from information security incidents.

Incident Lifecycle

1. Identification and reporting
2. Triage and severity classification
3. Containment and eradication
4. Recovery and service validation
5. Post-incident review and lessons learned

Escalation Principles

- High-severity incidents require notification of security leadership and relevant business owners without delay.
- Potential legal, regulatory, or privacy impacts must be coordinated with legal and privacy stakeholders.
- Customer or external communications must be approved through designated communications channels.